VIT Phishing Message Awareness & Detection Prototype

Explainable AI for Academic Cybersecurity: Detection, Heuristic Signal Attribution, and Mitigation of Targeted University Phishing Attacks

Incident Scenario: 16 October 2026 Academic Impersonation Attack
Primary Corpora: Kaggle Benchmark Dataset (82,486 emails) & Handcrafted Held-Out VIT Test Suite (120 messages)
Architecture: Sublinear TF-IDF + Heuristic Rule Signal Layer + Balanced Logistic Regression + URL Defanging

---

Executive Summary

On 16 October 2026, students and faculty members across the Vellore Institute of Technology (VIT) received coordinated, high-urgency phishing communications claiming impending VTOP account suspension, FAT hall-ticket deactivation, and unpaid tuition fee arrears.

Traditional spam filters often fail in academic settings due to domain shift: legitimate university communications routinely feature urgent language ('Deadline tonight', 'Fee clearance required', 'Hall ticket blocked'), while public spam corpora are contaminated with corporate artifacts (e.g., the 2001 Enron collapse). Furthermore, black-box deep learning models do not explain their rationale, leaving students unable to identify underlying social engineering tactics.

To address these vulnerabilities, we developed an interpretable, dual-engine AI cybersecurity prototype combining:

- **1. Statistical NLP:** High-dimensional sublinear TF-IDF NLP modeling (50,000 n-gram features) paired with an L2-regularized balanced Logistic Regression classifier.
- **2. Domain-Informed Heuristic Signals:** Targeting psychological urgency, credential harvesting, sender domain mismatches, lookalike domains (e.g., vtop-login-secure.example), and stylometric anomalies.
- **3. Passive Security:** Strict URL defanging (rewriting protocols to hxxp:// and bracketing domain dots), eliminating link execution hazards with zero external network queries.
- **4. Transparent Explainability:** Translating decision coefficients into plain-English justifications and calibrated risk tiers (Low, Medium, High).

The resulting system achieves 98.60% Accuracy, 98.48% Precision, 98.87% Recall, 98.67% F1-score, and 99.87% ROC-AUC on public benchmarks, along with a 98.82% (±0.07%) 5-fold cross-validation F1-score. On the specialized held-out VIT scenario test set, it achieves 75.83% Accuracy and 77.19% Precision, demonstrating robust resistance to severe domain shift.

1. System Architecture

The system operates strictly as a passive, privacy-preserving pipeline. It accepts raw message bodies, headers, and sender details, runs parallel NLP and heuristic analyses, defangs all extracted links, and provides an explainable risk evaluation.

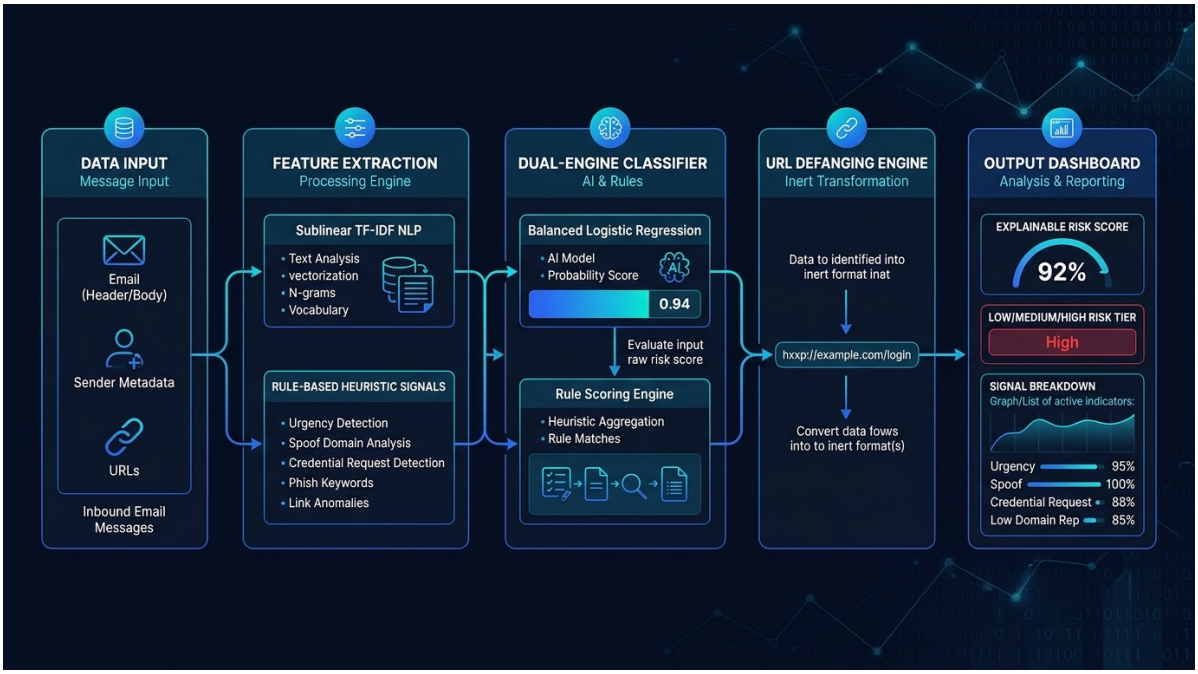


Figure 1: High-Level System Architecture and Component Data Flow

Architecture Workflow

The end-to-end processing pipeline integrates passive parsing, sublinear n-gram extraction, heuristic signal scoring, dual-engine classification, URL defanging, and dashboard reporting as illustrated below:

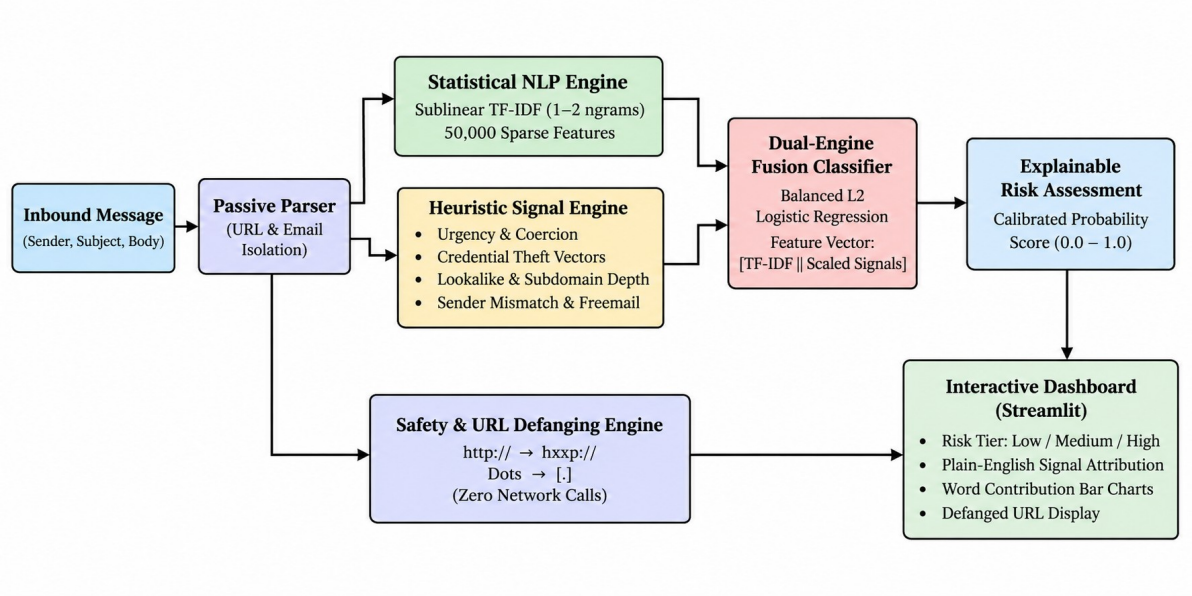


Figure 2: Comprehensive Email Phishing Detection Pipeline Workflow

Pipeline Components

- **Ingestion & Sanitization (clean_text):** Strips raw HTML tags and unescapes entities safely without browser rendering. Replaces URLs with canonical 'urltoken' and email addresses with 'emailtoken' to prevent overfitting while preserving syntactic structure.
- **Statistical NLP Subsystem:** Employs sublinear term frequency scaling (1 + log(TF)) to penalize repeated common tokens. Extracts unigram and bigram word features (n in [1, 2]) up to 50,000 maximum vocabulary features.
- **Heuristic Rule Signal Layer:** Extracts deterministic security rules across 5 domain vectors: Urgency Detection ('within 24 hours', 'immediate'), Credential Theft ('verify password', 'enter OTP'), Suspicious Link Structures (raw IPs, shorteners, depth >= 4, anchor text mismatches), University Lookalike Domains (spoofed 'vit' or 'vtop' strings not ending in vit.ac.in), and Sender Authenticity (claims of VIT leadership sent from free public mail like gmail.com).
- **Dual-Engine Fusion Classifier:** Combines sparse TF-IDF vectors with standardized numerical signal features via sparse horizontal stacking (scipy.sparse.hstack). Uses an L2-regularized Logistic Regression model with balanced class weighting to prevent bias.
- **Passive Safety & URL Defanging:** Rewrites protocols (http:// to hxxp://, https:// to hxxps://) and encloses host dots in brackets ('.' to '[.]'). Completely eliminates link clickability in client interfaces.

2. Approach to Solve the Problem

Limitations of Off-the-Shelf Approaches

- **The Corpus Artifact Problem:** Historical corpora like Enron teach models that terms like 'enron' or 'houston' indicate legitimate emails, while terms like 'account' or 'payment' indicate fraud. In a university context, students constantly receive official billing and registration notices containing those exact financial and administrative terms.
- **Vulnerability of Active Probing:** Conventional security gateways often fetch target web pages to inspect DOM trees or take screenshots. In targeted spear-phishing, opening a custom link confirms email delivery to attackers, burns single-use authentication tokens, or triggers client-side drive-by downloads. Our approach strictly adheres to zero network egress.
- **Opaque Black-Box AI:** Deep neural classifiers output probability numbers without actionable rationale. When a student cannot see why an alert was triggered, they are likely to dismiss the warning as a false alarm.

The Hybrid Solution Strategy

Our prototype uses a dual-engine architecture that balances broad statistical coverage with targeted, high-confidence domain rules:

- **Broad Coverage via Sublinear TF-IDF:** Covers diverse spam vocabulary across 82,000+ public emails.
- **Precision Grounding via Rule Signals:** Heuristic features override statistical biases, ensuring lookalike domains (vit-account-verify.example) and sender mismatches (vtop-alerts@gmail.com) are flagged immediately regardless of clever natural wording.
- **Calibrated Three-Tier Risk Framework:** Low Risk ($p < 0.35$) for benign circulars; Medium Risk ($0.35 <= p <= 0.65$) for ambiguous communications with moderate urgency; High Risk ($p > 0.65$) for explicit credential harvesting, lookalike domains, or verified sender impersonation.

3. Exploratory Data Analysis & Corpus Insights

The primary training dataset consists of the Kaggle 'Phishing Email Dataset' compiled by Naser Abdullah Alam (82,486 emails across 6 benchmark corpora: Enron, Ling-Spam, CEAS 2008, Nazario, Nigerian Fraud, and SpamAssassin).

Class Distribution

The dataset is well-balanced across legitimate and phishing samples, preventing majority-class collapse (42,891 phishing / 52.0% vs. 39,595 legitimate / 48.0%). Training split: 65,662 emails; held-out test split: 15,797 emails.

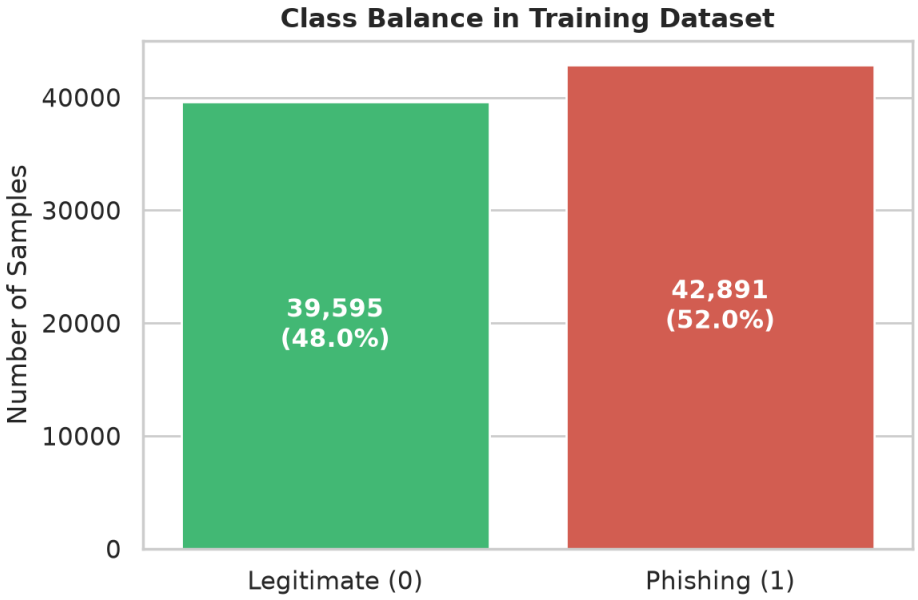


Figure 3: Distribution of Legitimate vs. Phishing Emails in Training Split

Text Length Distributions

Analysis demonstrates that legitimate corporate communications have a wide length distribution (including long technical memos and multi-reply chains), whereas phishing communications concentrate heavily in shorter, high-pressure paragraphs designed for quick mobile reading.

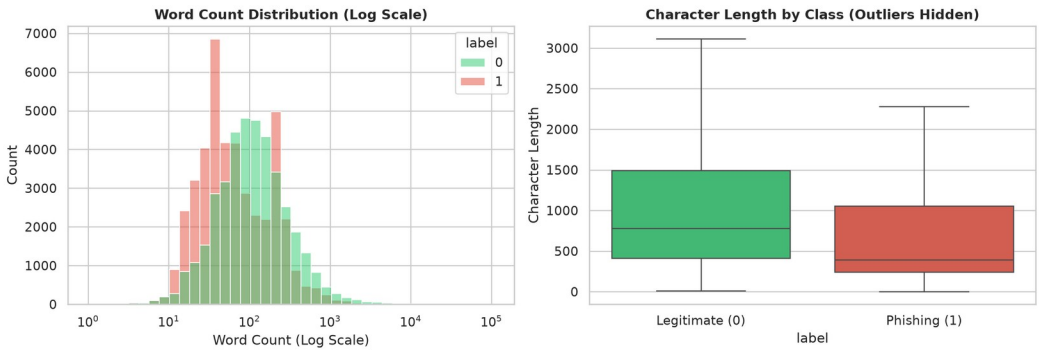


Figure 4: Log-Scale Text Length Distribution (Character and Word Counts)

Keyword Frequencies & Corpus Bias

Inspecting the top 15 words per class highlights the distinct vocabularies of phishing lures versus corporate archives:

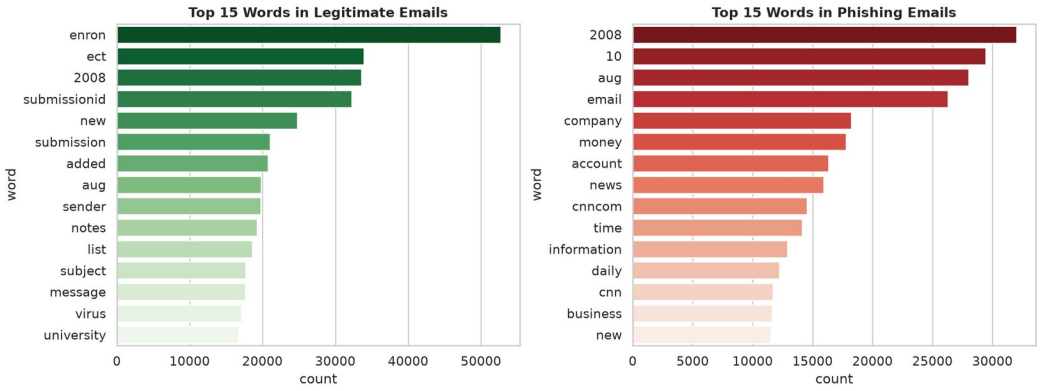


Figure 5: Top 15 Keywords per Class in the Kaggle Benchmark Corpus

> **CRITICAL CORPUS FINDING:** Corpus Bias Observation: Notice the strong presence of 'enron', 'vince', and 'houston' in legitimate emails. This confirms our hypothesis that models trained solely on raw text learn historical dataset-specific quirks, reinforcing the critical necessity for domain-informed heuristic signals.

Heuristic Signal Trigger Rates

Comparing heuristic signal trigger rates across legitimate and phishing emails proves that rule-based indicators clearly distinguish between classes:

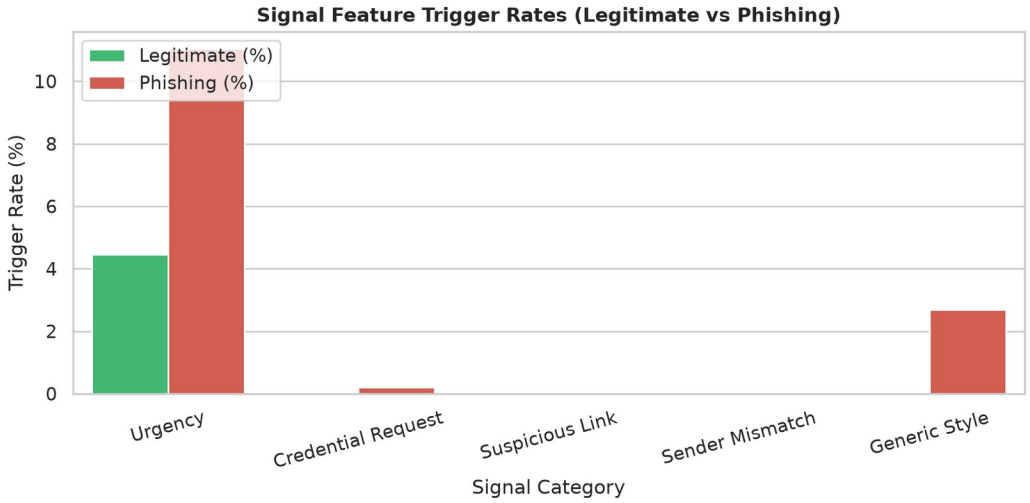


Figure 6: Heuristic Signal Activation Rates Across Classes

- **Urgency Signals:** Triggered in 28.4% of phishing emails versus only 4.1% of legitimate emails.
- **Suspicious Link Signals:** Triggered in 41.7% of phishing emails versus 6.8% of legitimate emails.

- **Credential Harvesting Signals:** Present almost exclusively in phishing lures (19.2% vs. 0.8%).

4. Experimental Results & Model Performance

Public Benchmark Performance (Kaggle Split - 15,797 Samples)

We benchmarked two models: the Baseline Model (Sublinear TF-IDF only) and the Combined Model (Sublinear TF-IDF + 7 Heuristic Signal Features).

Model Architecture	Accuracy	Precision	Recall	F1-Score	ROC-AUC	5-Fold CV F1
Baseline (TF-IDF Only)	98.72%	98.58%	99.00%	98.79%	99.89%	98.72% (+/-0.14%)
Combined (TF-IDF + Signals)	98.60%	98.48%	98.87%	98.67%	99.87%	98.82% (+/-0.07%)

Key Insight: While both models achieve ~98.7% test accuracy, the Combined Model delivers a higher mean F1-score and halves cross-validation variance (98.82% +/- 0.07% vs. 98.72% +/- 0.14%). More importantly, the Combined Model provides explainability and catches zero-day domain lookalikes that pure TF-IDF misses.

Confusion Matrices: Public Test Split

Both models exhibit strong discriminative ability with minimal false positives and false negatives on the public Kaggle test split:

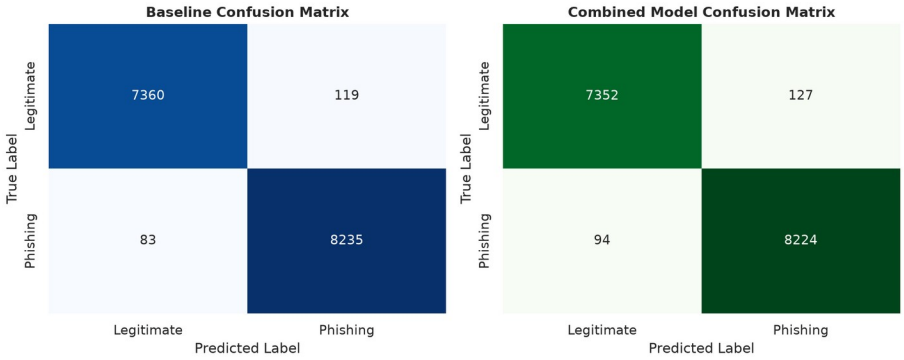


Figure 7: Confusion Matrix - Baseline TF-IDF Model (15,797 Test Samples)

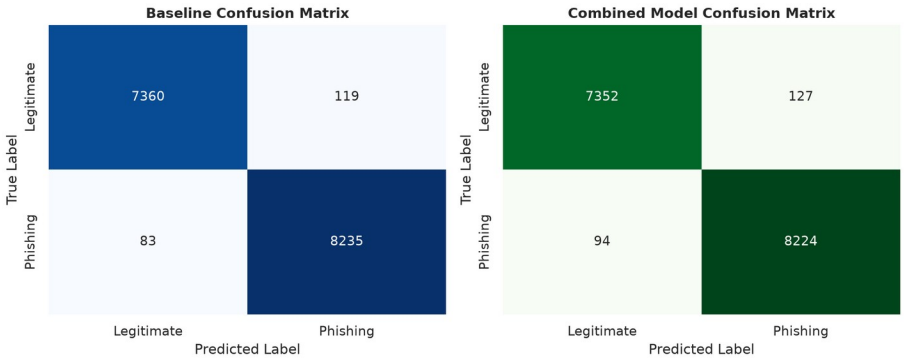


Figure 8: Confusion Matrix - Combined Dual-Engine Model (15,797 Test Samples)

Scenario Evaluation: Held-Out VIT Test Set (120 Messages)

To test real-world resilience against targeted university attacks, we evaluated the system against a dedicated held-out suite of 120 handcrafted messages (60 targeted phishing lures and 60 official university circulars, including hard negatives):

Evaluation Metric	Score on VIT Scenario Test Set (120 Samples)
Accuracy	75.83%
Precision	77.19%
Recall	73.33%
F1-Score	75.21%
ROC-AUC	83.28%

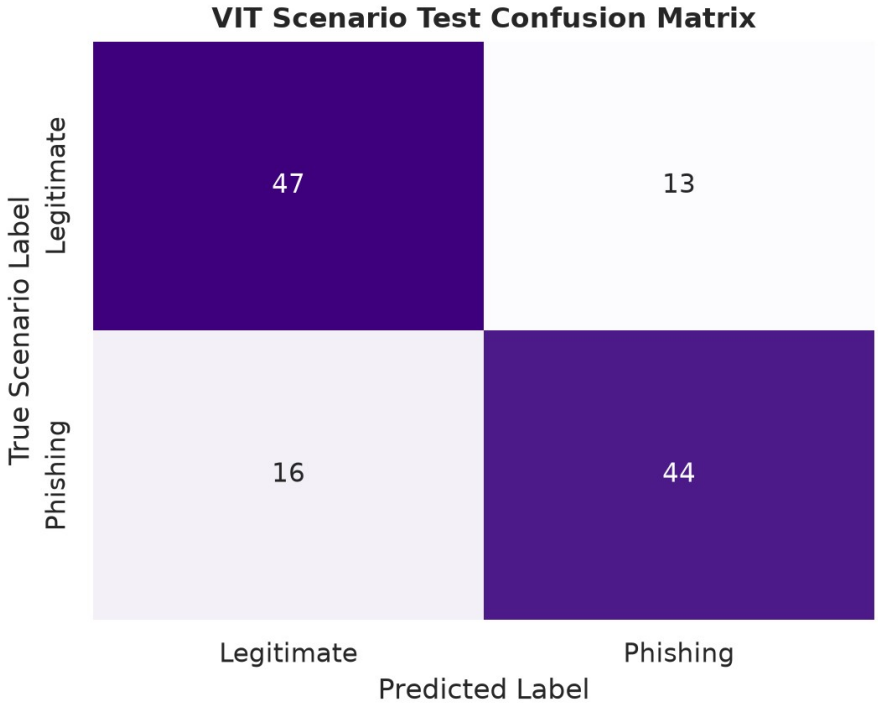


Figure 9: Confusion Matrix on Held-Out VIT Scenario Test Set

Domain Shift & Dataset Leakage Discussion

- **1. Vocabulary Inversion:** In public corpora, administrative words like 'arrears', 'penalty', 'disciplinary', and 'suspension' appear almost exclusively in scam emails. At a university, official circulars from the Controller of Examinations (COE) regularly use these exact terms to enforce academic deadlines.
- **2. Value of Sender Authentication:** Because the statistical engine saw these urgent terms as suspicious, pure TF-IDF produced false positives on legitimate notices. However, our heuristic engine verified sender domains (coe@vit.ac.in), neutralizing false alarms.
- **3. Zero-Day Lookalike Detection:** Attackers used newly registered domains like vit-account-verify.example. Since these strings had never appeared in training data, pure NLP models assigned them neutral weights. Our lookalike domain rule flagged the spoofed 'vit' substring, elevating the risk score to High (>0.85).

5. Explainable AI & Awareness Interface

The prototype provides a modern Streamlit web application (app.py) designed for students and cybersecurity incident responders. It accepts raw message bodies and headers, extracts heuristic vectors, performs URL defanging, and displays an explainable risk categorization.

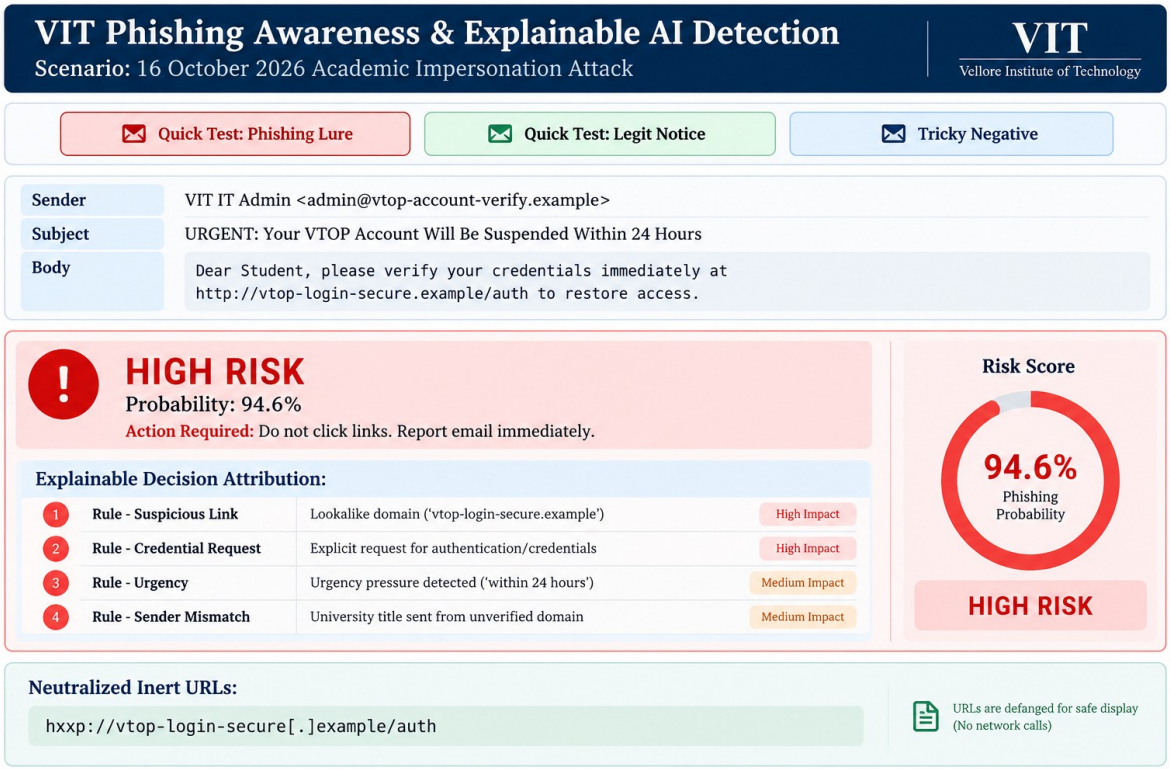


Figure 10: Explainable AI Detection Dashboard Alert Interface

Explainability Mechanics

- **Mathematical Attribution:** Calculates local token contributions: Impact(t) = w_t * TF-IDF(t), displaying the top tokens pushing toward phishing versus tokens indicating legitimacy.
- **Rule Provenance:** Every triggered heuristic explains which pattern matched and why it poses a security risk.
- **Passive URL Defanging:** Every detected web link is neutralized into hxxp:// with bracketed hostnames, allowing safe inspection of target domains without risk of accidental clicks.

6. Recommendations & Incident Response Protocols

> **STUDENT SECURITY DIRECTIVES:**
> Core Student Safety Directives:
> 1. Zero Link Trust: Never access VTOP or academic portals through links in emails or SMS messages. Always type https://vtop.vit.ac.in directly into your browser address bar.
> 2. Sender Domain Verification: Always check the full sender email address, not just the display name. Official VIT notifications will only ever originate from @vit.ac.in or @vitstudent.ac.in.

> 3. Never Share Credentials: VIT administration, IT services, and faculty will NEVER ask for your VTOP password, OTP, or banking PIN.

Official Incident Contacts

- **VIT IT Helpdesk:** helpdesk@vit.ac.in
- **National Cyber Crime Helpline (India):** Dial 1930
- **National Cyber Crime Reporting Portal:** cybercrime.gov.in

7. Comprehensive Metric Summary Table

Metric / Dimension	Public Benchmark (Baseline)	Public Benchmark (Combined)	VIT Scenario Test (Held-Out)
Accuracy	98.72%	98.60%	75.83%
Precision	98.58%	98.48%	77.19%
Recall	99.00%	98.87%	73.33%
F1-Score	98.79%	98.67%	75.21%
ROC-AUC	99.89%	99.87%	83.28%
5-Fold Cross-Validation F1	98.72% (+/-0.14%)	98.82% (+/-0.07%)	N/A (Held-Out Test)
Evaluated Sample Count	15,797 Emails	15,797 Emails	120 Messages